

Plataforma Educativa

CMS educativo interactivo para infantil y primaria

Manual Tecnico y de Usuario - V-0.19.1

Endurecimiento de seguridad: el contenedor del backend ya NO ejecuta la aplicacion como root. Se crea un usuario sin privilegios (appuser) y, mediante gosu, el entryptpoint baja privilegios tras ajustar los permisos de los volúmenes. Principio de menor privilegio: reduce el daño ante una eventual RCE. Cambio solo de infraestructura (Dockerfile + entryptpoint), sin tocar código, API ni esquema.

Fecha: 2026-06-17

Version del software: V-0.19.1

Licencia: MIT (open source)

NOVEDADES DE V-0.19.1

0. Backend sin privilegios (usuario no-root)

Que cambia

- El contenedor del backend ya NO ejecuta la aplicacion como root. Principio de menor privilegio: si apareciera una RCE, el proceso comprometido no seria root dentro del contenedor (dificulta escalar y escapar).
- Dockerfile: instala gosu y crea el usuario appuser (UID/GID 10001, configurables con los build-args APP_UID/APP_GID).
- entrypoint.sh: arranca como root SOLO para hacer chown de los bind mounts (/app/data y /app/media) y luego se reinvoca con 'gosu appuser'. Migraciones, seed y uvicorn corren ya sin privilegios (patron de la imagen oficial de postgres).

Notas

- Cambio SOLO de infraestructura (Dockerfile + entrypoint + docs); sin cambios de codigo, API ni esquema. NO hay migracion nueva. 205 tests backend en verde.
- REQUIERE validar en el servidor (Docker no esta en el entorno de desarrollo).

PARTE I - MANUAL TECNICO

1. Ficheros afectados

backend/Dockerfile	Instala gosu; crea appuser (ARG APP_UID/APP_GID); chown data/media
backend/entrypoint.sh	Arranca root, chown de bind mounts y baja a appuser con gosu
docs/seguridad-imagenes.md	Documenta el setup no-root y la validacion en el servidor

2. Despliegue

```
cd plataforma-educativa
docker compose up -d --build
# alembic upgrade head corre ya como appuser. Esta version NO anade migraciones.
# Alinear con un UID/GID del host:
docker compose build --build-arg APP_UID=<uid> --build-arg APP_GID=<gid> api
```

3. Validacion en el servidor

```
# 1) uvicorn corre como appuser (no root):
docker compose exec api ps -o user,pid,comm
# 2) sin errores de permisos; migraciones y seed correctos:
docker compose logs api | grep -i -E "permission|denied|alembic|admin"
```

Si los bind mounts tenian ficheros de propietario root de versiones anteriores, el chown del entrypoint los reasigna a appuser en el primer arranque (coste unico; puede tardar algo si ./media tiene muchos ficheros).

4. Seguridad

- El healthcheck del compose se ejecuta via docker exec (root); solo hace un urlopen a localhost:8000/health, no requiere privilegios y sigue funcionando.
- Aislamiento del sandbox, sanitizacion asimetrica del HTML de articulos y tratamiento de datos de menores: sin cambios.

5. Tests

```
cd backend && python -m pytest tests/unit tests/integration -q # 205
cd frontend && npm run test:e2e # 9 E2E
```

PARTE II - MANUAL DE USUARIO

6. Sin cambios visibles

Esta version no introduce cambios visibles para administradores, editores ni visitantes: es una mejora interna de seguridad del despliegue.

7. Roadmap

Hecho (V-0.19.1)	Backend sin privilegios (usuario no-root con gosu) en Docker.
Hecho (V-0.19.0)	Iconos de red en articulos + autor de cada version.
Pendiente (UI)	Pie de la web siempre visible; acciones admin/editor siempre visibles.